

# GOVERN.AI

## ANTHERA Systems

MANUALE OPERATIVO

VERSION

**MVP v3.1**

DATE

**21 Maggio 2026**

AUTHOR

**ANTHERA Systems**

CLASSIFICATION

**Confidential**

*Manuale completo - utente, implementazione, deploy.*

**Guida operativa completa: utilizzo della piattaforma, estensione tecnica, deploy in produzione.**

**Versione:** MVP v3.0

**Data:** 14 Maggio 2026

**Autore:** ANTHERA Systems

**Destinatari:** Compliance Manager, DPO, CISO, AI Engineer, DevOps, Solution Architect

# Indice

## PARTE 1 — GUIDA UTENTE

- Introduzione alla piattaforma
- Login, accesso e sicurezza
- Navigazione principale
- Overview Dashboard
- AI Agent Registry
- Policy Engine + Policy Guidance
- SOX Section 404 Wizard
- Compliance Monitor (8 standard)
- Audit Trail
- Intelligence Center (Score Center)
- ARIA — Assistente AI
- Export PDF/CSV
- Internazionalizzazione IT/EN

## PARTE 2 — GUIDA IMPLEMENTAZIONE

- Architettura tecnica
- Modelli dati (MongoDB)
- API REST (endpoints completi)
- Compliance Intelligence Engine
- Personalizzazione policy e standard
- Integrazione LLM (litellm)
- Estensione del frontend
- RBAC e sicurezza

## PARTE 3 — GUIDA DEPLOY

- Setup locale (Docker Compose)
- Variabili d'ambiente
- Seed iniziale e demo data
- Deploy in produzione (Docker + Nginx)
- CI/CD GitHub Actions
- Monitoring, logging, backup
- Troubleshooting comune
- Appendice — Credenziali e link utili

# PARTE 1 — GUIDA UTENTE

## 1. Introduzione alla piattaforma

GOVERN.AI è il control plane sovrano per la governance degli agenti AI nelle aziende che operano in settori regolamentati (banche, assicurazioni, sanità, PA, infrastrutture critiche).

Permette di:

- **Censire** ogni agente AI con classificazione del rischio (EU AI Act)
- **Definire** policy granulari per ogni normativa
- **Rilevare** conflitti tra policy con guidance operativa
- **Quantificare** la postura di compliance con uno score deterministico (0-100)
- **Guidare** i Compliance Officer attraverso wizard SOX 404
- **Tracciare** ogni azione AI in un audit trail spiegabile
- **Monitorare** real-time 8 standard internazionali
- **Esportare** report PDF/CSV pronti per regolatori e audit

### A chi si rivolge

| Persona                              | Esigenza principale                                    |
|--------------------------------------|--------------------------------------------------------|
| <b>**Compliance Manager / DPO**</b>  | Visibilità unificata, score quantitativo, gestione gap |
| <b>**CISO**</b>                      | Risk classification, audit trail, security headers     |
| <b>**Auditor (interno/esterno)**</b> | Audit Readiness Score, export PDF, evidence            |
| <b>**AI Engineer**</b>               | Registro agenti, lifecycle, policy enforcement         |
| <b>**CdA / Investor**</b>            | Intelligence Center, score posture, trend              |

## 2. Login, accesso e sicurezza

### Accesso

- Apri il browser su `http://localhost:3000` (o sull'URL del tuo deploy)
- Verrai indirizzato alla **Landing Page**
- Clicca su **"Get Started"** o **"Login"**
- Inserisci credenziali

### Credenziali demo

- **Username:** admin
- **Password:** AdminGovern2026!

In produzione cambia immediatamente queste credenziali. Vedi sezione 21 — Sicurezza.

Ruoli (RBAC)

| Ruolo       | Lettura | Scrittura | Cancellazione | Admin | Export |
|-------------|---------|-----------|---------------|-------|--------|
| **Admin**   | Si      | Si        | Si            | Si    | Si     |
| **DPO**     | Si      | Si        | No            | No    | Si     |
| **Auditor** | Si      | No        | No            | No    | Si     |
| **Viewer**  | Si      | No        | No            | No    | No     |

Sessione

- JWT firmato HS256, scadenza **8 ore**
- Il token viene salvato in localStorage del browser
- Logout: pulsante in alto a destra della sidebar

3. Navigazione principale

Sidebar (sinistra)

Dopo il login l'app mostra il layout dashboard con sidebar collassabile e 8 voci principali:

| Voce         | Pagina                    | Cosa contiene              |
|--------------|---------------------------|----------------------------|
| Overview     | `/dashboard/overview`     | KPI + 3 grafici principali |
| Agents       | `/dashboard/agents`       | Registro agenti AI         |
| Policies     | `/dashboard/policies`     | Policy + Conflict Engine   |
| SOX 404      | `/dashboard/sox`          | Wizard controlli SOX       |
| Audit        | `/dashboard/audit`        | Audit Trail completo       |
| Compliance   | `/dashboard/compliance`   | 8 standard normativi       |
| Intelligence | `/dashboard/intelligence` | Score Center (v3.0)        |
| ARIA         | `/dashboard/assistant`    | Assistente AI              |

Cambio lingua

In alto a destra: toggle **IT / EN**.

## 4. Overview Dashboard

La pagina Overview mostra:

- **4 card KPI:** Agenti totali, Policy attive, Audit Log totali, Compliance Score complessivo
- **3 grafici Recharts:**
  - Distribuzione rischio (pie chart) - Audit outcome trend (line chart) - Compliance progress per standard (bar chart)
- **Score globale di governance** (banner v3.0): tile con score, trend, link rapido all'Intelligence Center

### Come leggere il Compliance Score

- **0-49:** Critico (rosso) - intervento immediato
- **50-69:** Warning (giallo) - gap da chiudere
- **70-89:** Good (verde chiaro) - posture solida
- **90-100:** Excellent (verde scuro) - best-in-class

## 5. AI Agent Registry

### Cosa contiene

Lista di tutti gli agenti AI registrati nell'organizzazione, con:

| Campo       | Descrizione                                        |
|-------------|----------------------------------------------------|
| Name        | Nome dell'agente                                   |
| Type        | Tipo (chatbot, classifier, advisor, monitor, etc.) |
| Risk Level  | low / medium / high / unacceptable (EU AI Act)     |
| Status      | active / inactive / under_review                   |
| Owner       | Team o persona responsabile                        |
| Description | Funzione di business                               |

### Operazioni

- **Crea** agente: pulsante "+ Add Agent" -> dialog con form
- **Modifica:** icona "matita" su riga
- **Cancella:** icona "cestino" su riga (solo Admin)
- **Filtra:** barra di ricerca + filtri per status e risk\_level

### Best practice

- Registra l'agente **prima** del deploy operativo

- Classifica il rischio coerentemente con l'EU AI Act
- Associa l'agente a una o più policy (vedi sezione 6)
- Usa nomi descrittivi (es. "Credit Scoring AI", "AML Monitor")

## 6. Policy Engine + Policy Guidance

### Policy

Una **policy** definisce una regola di governance applicata a uno o più agenti.

| Campo       | Descrizione                                         |
|-------------|-----------------------------------------------------|
| Name        | Nome policy                                         |
| Regulation  | Standard di riferimento (GDPR, EU AI Act, SOX, ...) |
| Severity    | low / medium / high / critical                      |
| Action      | allow / log / require_review / block                |
| Description | Cosa fa la policy                                   |
| Status      | active / draft / archived                           |

### Esempi pratici

- **\*Policy GDPR\***: "Log all credit decisions with reasoning" - action=log
- **\*Policy EU AI Act\***: "Block if biased input detected" - action=block
- **\*Policy SOX\***: "Require human approval for financial decisions" - action=require\_review

### Policy Conflict Engine (Step E4)

Cliccando il pulsante **"Run Conflict Scan"** il sistema rileva automaticamente 4 tipi di anomalie:

| Tipo                       | Descrizione                                            |
|----------------------------|--------------------------------------------------------|
| <b>**Action Conflict**</b> | Due policy con action contrastanti sullo stesso agente |
| <b>**Gap**</b>             | Standard normativo non coperto da alcuna policy        |
| <b>**Overlap**</b>         | Due policy sovrapposte sullo stesso scope              |
| <b>**Redundancy**</b>      | Policy duplicate con stessa azione                     |

### Policy Guidance Engine (Step E5 — v2.5)

Per ogni conflitto rilevato, GOVERN.AI fornisce:

- **Guidance contestuale**: cosa fare per risolverlo
- **Impact analysis**: priorit , urgenza, business risk

- **Resolve dialog**: form per registrare la decisione presa
- **Note di risoluzione obbligatorie** (auditabili)
- **Audit log automatico** dell'intervento

## Workflow tipico

- Crea/importa policy per ogni standard rilevante
- Esegui scan conflitti
- Apri ogni conflitto -> leggi guidance -> decidi azione
- Compila note di risoluzione -> conferma
- Verifica nel Audit Trail la registrazione

## 7. SOX Section 404 Wizard

### Cosa fa

Wizard guidato per la valutazione dei **20 controlli SOX 404** suddivisi in **5 domini**:

- **Access Control** (4 controlli)
- **Change Management** (4 controlli)
- **IT Operations** (4 controlli)
- **Data Integrity** (4 controlli)
- **Security** (4 controlli)

### Workflow

- Apri la pagina **SOX 404**
- Seleziona un controllo: stato iniziale **not\_started**
- Cambia stato in:
  - **in\_progress** (attività in corso) - **completed** (controllo soddisfatto) - **failed** (gap aperto)
- Aggiungi evidence/notes nel dialog di edit
- Esporta il **SOX 404 Report PDF**

### Audit Readiness Score

In fondo alla pagina, un **score pesato per rischio** (0-100%) indica quanto sei pronto per un audit SOX. Calcolato considerando:

- Numero di controlli completed vs. totali
- Peso del dominio (Security/Access Control = peso più alto)
- Numero di controlli failed (penalità)



## 8. Compliance Monitor (8 standard)

### Standard tracciati

| Standard        | Descrizione                    | Progress demo |
|-----------------|--------------------------------|---------------|
| EU AI Act       | Regolamento europeo AI         | 45%           |
| GDPR            | Protezione dati personali      | 78%           |
| ISO 27001       | Information Security Mgmt      | 92%           |
| ISO 42001       | AI Management System           | 34%           |
| DORA            | Digital Operational Resilience | 61%           |
| NIS2            | Cybersecurity Directive        | 83%           |
| SOX             | Sarbanes-Oxley (Section 404)   | 56%           |
| D.Lgs. 262/2005 | Controlli finanziari italiani  | 48%           |

### Cosa puoi fare

- Vedere progress, status, ultimo aggiornamento per standard
- Filtrare per status (Compliant / In Progress / Non Compliant)
- Aprire dettaglio con KPI specifici
- Esportare **Compliance Report PDF**

## 9. Audit Trail

### Cosa contiene

Log completo di ogni azione tracciabile della piattaforma:

| Campo      | Descrizione                 |
|------------|-----------------------------|
| Timestamp  | Data/ora ISO 8601 (UTC)     |
| Agent      | Agente AI coinvolto         |
| Action     | Azione tentata              |
| Outcome    | success / blocked / flagged |
| Risk Level | low / medium / high         |
| Details    | Spiegabilita (JSON)         |

## Filtri

- Per data (range picker)
- Per agente
- Per outcome
- Per risk level

## Export

- **PDF**: report formattato per audit esterno
- **CSV**: per analisi BI

---

# 10. Intelligence Center (v3.0)

## Cosa contiene

Dashboard premium investor-ready con:

- **Score Ring** centrale (governance score complessivo)
- **KPI breakdown**: 4 dimensioni di valutazione (Agents, Policies, Audit, Compliance)
- **Top/Bottom agents** per score
- **Score per standard** (8 mini-tile)
- **Drivers positivi e negativi**: cosa contribuisce in positivo/negativo
- **Methodology note**: come è calcolato lo score
- **Insights, rischi, remediation**: azioni consigliate
- **Score History**: snapshot con delta e trend

## Come si calcola lo score

Algoritmo deterministico (vedi sezione 17) che considera:

- Distribuzione del rischio degli agenti
- Status delle policy e conflitti aperti
- Audit outcome trend (success vs blocked)
- Progress dei controlli SOX 404
- Coverage dei 8 standard

## Use case Investor

L'Intelligence Center è progettato per essere mostrato in board meeting / due diligence:

- 1 score sintetico (KPI principale)
- Trend storico (validation che la posture migliora)
- Driver list (trasparenza)
- Remediation (visibilità futura)

# 11. ARIA — Assistente AI

## Cosa fa

ARIA è un consulente AI esperto delle 8 normative tracciate dalla piattaforma. Risponde in chat in **streaming SSE** con la conoscenza specifica di:

- EU AI Act
- GDPR
- ISO 27001 / 42001
- DORA / NIS2
- SOX / D.Lgs. 262

## Come si usa

- Apri pagina **ARIA**
- Scrivi una domanda (es. **"Quali controlli SOX devo applicare al credit scoring?"**)
- ARIA risponde in streaming
- Le conversazioni sono **persistite per sessione**

## Contestualizzazione v3.0

ARIA conosce in tempo reale:

- Lo score di governance corrente
- I conflitti policy aperti
- I gap dei controlli SOX

E quindi può dare consigli **contestualizzati** sul tuo stato di compliance.

# 12. Export PDF/CSV

| Report            | Endpoint                                     | Formato       |
|-------------------|----------------------------------------------|---------------|
| Audit Trail       | <code>/api/audit/export/pdf` o `/csv`</code> | PDF / CSV     |
| Compliance Report | <code>/api/compliance/export/pdf`</code>     | PDF           |
| SOX 404 Report    | <code>/api/sox/report/pdf`</code>            | PDF           |
| Investor Score    | dal Intelligence Center                      | PDF (manuale) |

Tutti i report sono generati con **ReportLab** in stile branded GOVERN.AI.

# 13. Internazionalizzazione

- **IT/EN** completamente tradotti (~140 chiavi i18n)

- Toggle in alto a destra
  - Tutte le pagine, i form, i tooltip e i toast sono localizzati
-

## PARTE 2 — GUIDA IMPLEMENTAZIONE

## 14. Architettura tecnica

[illegible]

## Layer

- **Frontend SPA:** React 19, Tailwind, Shadcn UI, Recharts, i18n custom
- **Backend modulare:** server.py registra 10 router (auth, agents, policies, audit, compliance, dashboard, chat, sox\_wizard, policy\_engine, score)
- **Service layer:** services/compliance\_engine.py per logica di scoring
- **Database:** MongoDB con Motor async, 15+ indici ottimizzati
- **LLM:** portabile via litellm (default openai/gpt-4o)
- **Security:** JWT HS256, bcrypt, SlowAPI rate limit, 5 security headers, CORS restrittivo

# 15. Modelli dati (MongoDB)

## Collections

| Collection             | Documenti tipici | Indici chiave                                           |
|------------------------|------------------|---------------------------------------------------------|
| `users`                | 1+               | id (unique), username (unique)                          |
| `agents`               | 14 demo          | id (unique), status, risk_level                         |
| `policies`             | 20+ demo         | id (unique), regulation, severity                       |
| `audit_logs`           | 150+ demo        | id (unique), timestamp, agent_name, outcome, risk_level |
| `compliance_standards` | 8 demo           | id (unique), code (unique)                              |
| `chat_messages`        | variabile        | session_id + timestamp (compound)                       |
| `sox_controls`         | 20               | id (unique), domain, status                             |

## Esempio: Agent

```
{
  "id": "uuid-1234",
  "name": "Credit Scoring AI",
  "type": "classifier",
  "risk_level": "high",
  "status": "active",
  "owner": "Risk Management",
  "description": "Automated credit decision support",
  "created_at": "2026-05-14T08:00:00Z"
}
```

## Esempio: Policy (con conflict resolution v2.5)

```
{
  "id": "uuid-5678",
  "name": "GDPR – Log all decisions",
  "regulation": "GDPR",
  "severity": "high",
  "action": "log",
  "description": "...",
  "status": "active",
  "conflicts": [{
    "type": "overlap",
    "with_policy_id": "uuid-other",
    "guidance": "Merge policies into a single comprehensive rule",
    "impact": "medium",
    "resolution_notes": "Merged 2026-05-10 by user@example.com",
    "resolved_at": "2026-05-10T10:00:00Z"
  }]
}
```

## 16. API REST (endpoints completi)

Tutti gli endpoint sono prefissati con `/api`. Auth tramite header `Authorization: Bearer .`

### Authentication

| Method | Endpoint                         | Descrizione                 |
|--------|----------------------------------|-----------------------------|
| POST   | <code>/api/auth/login`</code>    | Login (username + password) |
| POST   | <code>/api/auth/register`</code> | Registrazione (solo admin)  |
| GET    | <code>/api/auth/me`</code>       | Profilo utente corrente     |

### Agents

| Method | Endpoint                       | Descrizione               |
|--------|--------------------------------|---------------------------|
| GET    | <code>/api/agents`</code>      | Lista agenti (con filtri) |
| POST   | <code>/api/agents`</code>      | Crea agente               |
| PATCH  | <code>/api/agents/{id}`</code> | Aggiorna agente           |
| DELETE | <code>/api/agents/{id}`</code> | Elimina agente            |

### Policies & Policy Engine

| Method | Endpoint                                                 | Descrizione                       |
|--------|----------------------------------------------------------|-----------------------------------|
| GET    | <code>/api/policies`</code>                              | Lista policy                      |
| POST   | <code>/api/policies`</code>                              | Crea policy                       |
| PATCH  | <code>/api/policies/{id}`</code>                         | Aggiorna                          |
| DELETE | <code>/api/policies/{id}`</code>                         | Elimina                           |
| GET    | <code>/api/policy-engine/conflicts`</code>               | Scansiona conflitti               |
| GET    | <code>/api/policy-engine/conflicts/{id}/guidance`</code> | Guidance dettagliata (v2.5)       |
| POST   | <code>/api/policy-engine/conflicts/{id}/resolve`</code>  | Risolvi conflitto con note (v2.5) |
| GET    | <code>/api/policy-engine/scan-history`</code>            | Storico scan                      |

## Audit Trail

| Method | Endpoint                             | Descrizione                     |
|--------|--------------------------------------|---------------------------------|
| GET    | <code>`/api/audit`</code>            | Lista log con filtri (paginato) |
| GET    | <code>`/api/audit/export/pdf`</code> | Export PDF                      |
| GET    | <code>`/api/audit/export/csv`</code> | Export CSV                      |

## Compliance

| Method | Endpoint                                  | Descrizione        |
|--------|-------------------------------------------|--------------------|
| GET    | <code>`/api/compliance`</code>            | Lista standard     |
| GET    | <code>`/api/compliance/{code}`</code>     | Dettaglio standard |
| GET    | <code>`/api/compliance/export/pdf`</code> | Report PDF         |

## Dashboard

| Method | Endpoint                            | Descrizione  |
|--------|-------------------------------------|--------------|
| GET    | <code>`/api/dashboard/stats`</code> | KPI overview |

## SOX Wizard

| Method | Endpoint                                | Descrizione              |
|--------|-----------------------------------------|--------------------------|
| GET    | <code>`/api/sox/controls`</code>        | Lista 20 controlli       |
| PATCH  | <code>`/api/sox/controls/{id}`</code>   | Aggiorna stato controllo |
| GET    | <code>`/api/sox/report`</code>          | Report JSON              |
| GET    | <code>`/api/sox/report/pdf`</code>      | Report PDF               |
| GET    | <code>`/api/sox/readiness-score`</code> | Audit Readiness Score    |



## Compliance Intelligence Engine (v3.0)

| Method | Endpoint                             | Descrizione                          |
|--------|--------------------------------------|--------------------------------------|
| GET    | <code>/api/score/overview`</code>    | Score di governance + explainability |
| GET    | <code>/api/score/agents`</code>      | Score per ogni agente                |
| GET    | <code>/api/score/agents/{id}`</code> | Score singolo agente                 |
| GET    | <code>/api/score/standards`</code>   | Score per ogni standard              |
| GET    | <code>/api/score/history`</code>     | History snapshot                     |
| GET    | <code>/api/score/insights`</code>    | Insights, rischi, remediation        |

## Chat (ARIA)

| Method | Endpoint                              | Descrizione         |
|--------|---------------------------------------|---------------------|
| POST   | <code>/api/chat`</code>               | Messaggio singolo   |
| GET    | <code>/api/chat/stream`</code>        | SSE streaming       |
| GET    | <code>/api/chat/sessions/{id}`</code> | Cronologia sessione |

## Documentazione interattiva

- **Swagger UI:** <http://localhost:8001/docs>
- **ReDoc:** <http://localhost:8001/redoc>

# 17. Compliance Intelligence Engine

## File

- `/app/backend/services/compliance_engine.py`

## Logica di scoring

Lo score di governance (0-100) viene calcolato come **media pesata** di:

| Dimensione        | Peso | KPI di base                                          |
|-------------------|------|------------------------------------------------------|
| <b>Agents</b>     | 0.25 | Rischio medio, status active, coverage policy        |
| <b>Policies</b>   | 0.25 | Active vs draft, conflitti aperti, coverage standard |
| <b>Audit</b>      | 0.20 | Outcome success vs blocked, trend ultimi 30 giorni   |
| <b>Compliance</b> | 0.30 | Progress medio degli 8 standard, gap critici         |

## Output strutturato

```
{
  "score": 87,
  "trend": "+4",
  "label": "Good",
  "breakdown": [
    {"dimension": "Agents", "score": 82, "weight": 0.25},
    {"dimension": "Policies", "score": 75, "weight": 0.25},
    {"dimension": "Audit", "score": 91, "weight": 0.20},
    {"dimension": "Compliance", "score": 94, "weight": 0.30}
  ],
  "positive_drivers": ["High ISO 27001 progress", "Low audit-blocked ratio"],
  "negative_drivers": ["EU AI Act gap", "3 open policy conflicts"],
  "methodology": "Weighted multi-dimensional deterministic score..."
}
```

## Snapshot history

Ogni scan genera uno snapshot persistito in `score_snapshots`, con timestamp + score + breakdown. Permette il calcolo del **delta/trend**.

# 18. Personalizzazione policy e standard

## Aggiungere uno standard

- Modifica `/app/backend/seed.py` -> array STANDARDS
- Aggiungi entry con code, name, description, progress
- Esegui python `backend/seed.py` per ricaricare

## Aggiungere una policy custom

- Via UI: pagina Policies -> "+ Add Policy"
- Via API: POST `/api/policies` con payload Pydantic

## Pesi dello score

Per modificare la pesatura aprire `/app/backend/services/compliance_engine.py` e cambiare il dizionario `DIMENSION_WEIGHTS`. I pesi devono sommare a 1.0.

# 19. Integrazione LLM (litellm)

## Default

- Provider: OpenAI
- Modello: `openai/gpt-4o`
- Variabili: `OPENAI_API_KEY`, `LLM_MODEL`

## Cambio provider

Litellm supporta 100+ provider. Esempi:

- **Anthropic:** LLM\_MODEL=anthropic/claude-3-5-sonnet-20241022 + ANTHROPIC\_API\_KEY
- **Gemini:** LLM\_MODEL=gemini/gemini-1.5-pro + GEMINI\_API\_KEY
- **Locale (Ollama):** LLM\_MODEL=ollama/llama3.1 + OLLAMA\_API\_BASE

## Streaming

ARIA usa Server-Sent Events (SSE) tramite /api/chat/stream. Implementato in routes/chat.py.

# 20. Estensione del frontend

## Aggiungere una pagina

- Crea file in /app/frontend/src/pages/MyPage.js
- Esporta export default function MyPage() { ... }
- Aggiungi route in App.js dentro DashboardLayout
- Aggiungi link in sidebar (DashboardLayout.js)

## Aggiungere chiavi i18n

- /app/frontend/src/locales/it.json
- /app/frontend/src/locales/en.json

Usa t("my.key") nel componente con il hook del LanguageContext.

## Componenti riutilizzabili

- CrudPage per CRUD generici (vedi pagine Agents/Policies)
- EmptyState per stati vuoti
- SkeletonLoader per loading
- Componenti Shadcn in /components/ui/

# 21. RBAC e sicurezza

## Decoratore route

```
@router.get("/agents")
@require_role("auditor") # auditor o superiore
async def list_agents(...):
    ...
```

## Security headers

Middleware in `server.py` applica:

- `X-Frame-Options: DENY`
- `X-Content-Type-Options: nosniff`
- `Referrer-Policy: same-origin`
- `Content-Security-Policy: ...`
- `Strict-Transport-Security: ...` (in produzione)

## Rate limiting

SlowAPI applica limiti per IP:

- `/api/auth/login: 5/minuto`
- `/api/chat/*: 30/minuto`
- Default: 100/minuto

## Password hashing

bcrypt con cost factor 12. Configurato in `routes/auth.py`.

---

# PARTE 3 — GUIDA DEPLOY

## 22. Setup locale (Docker Compose)

### Prerequisiti

- Docker >= 24.0
- Docker Compose >= 2.0
- Git

### Step

```
git clone https://github.com/AngeloAng94/GOVERN.AI
cd GOVERN.AI
cp .env.example backend/.env
cp .env.example frontend/.env
docker-compose up --build
```

Apri <http://localhost:3000>. Credenziali: admin / AdminGovern2026!.

### Servizi avviati

| Servizio | Porta | Descrizione |
|----------|-------|-------------|
| frontend | 3000  | React SPA   |
| backend  | 8001  | FastAPI     |
| mongo    | 27017 | MongoDB 7.0 |

## 23. Variabili d'ambiente

### Backend (backend/.env)

| Variabile         | Obbligatoria | Descrizione                         |
|-------------------|--------------|-------------------------------------|
| `MONGO_URL`       | Si           | Connessione MongoDB                 |
| `DB_NAME`         | Si           | Nome database                       |
| `OPENAI_API_KEY`  | Si           | API key LLM (o equivalente litellm) |
| `LLM_MODEL`       | No           | Default `openai/gpt-4o`             |
| `JWT_SECRET_KEY`  | Si           | Stringa >=32 caratteri              |
| `ALLOWED_ORIGINS` | Si           | CSV di origin autorizzate           |

Frontend (frontend/.env)

| Variabile                           | Obbligatoria | Descrizione          |
|-------------------------------------|--------------|----------------------|
| <code>REACT_APP_BACKEND_URL`</code> | Si           | URL pubblico backend |

Non committare mai `.env` con valori reali. Usa `.env.example` come template.

24. Seed iniziale e demo data

Lo script `/app/backend/seed.py` carica:

- 1 utente admin
- 14 agenti AI enterprise
- 20+ policy con conflitti realistici
- 150+ audit log con 7 cluster di incidenti
- 8 standard normativi
- 20 controlli SOX 404

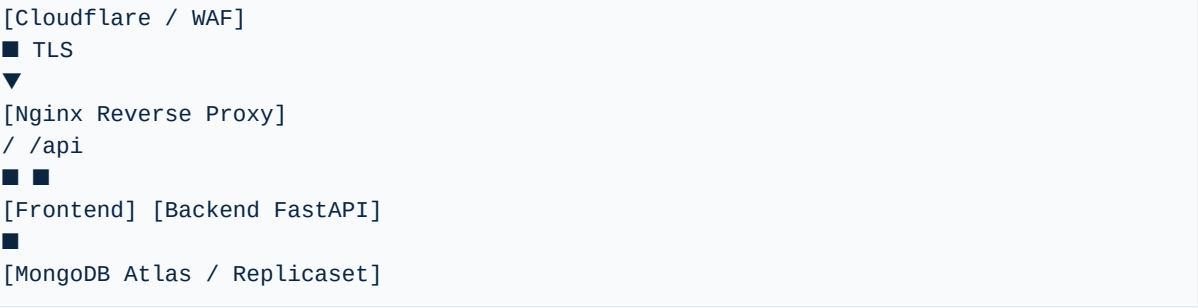
Esecuzione manuale

```
cd backend
python seed.py
```

Lo script e idempotente: se i dati esistono, li ricrea solo se la collection e vuota.

25. Deploy in produzione (Docker + Nginx)

Architettura suggerita



Nginx config minima

```
server {
  listen 443 ssl http2;
  server_name app.govern.ai;
  ssl_certificate /etc/letsencrypt/live/app.govern.ai/fullchain.pem;
  ssl_certificate_key /etc/letsencrypt/live/app.govern.ai/privkey.pem;

  location /api/ {
    proxy_pass http://backend:8001;
    proxy_set_header X-Real-IP $remote_addr;
    proxy_buffering off; # per SSE
    proxy_read_timeout 3600s;
  }

  location / {
    proxy_pass http://frontend:3000;
  }
}
```

Best practice

- TLS via Let's Encrypt
- WAF (Cloudflare, AWS WAF)
- MongoDB managed (Atlas)
- Secret rotation periodica per JWT\_SECRET\_KEY
- Backup giornalieri (vedi sezione 27)

26. CI/CD GitHub Actions

Il workflow `.github/workflows/ci.yml` esegue 4 job in parallelo a ogni push su `main` o `develop`:

| Job                           | Cosa fa                             |
|-------------------------------|-------------------------------------|
| <code>`backend-tests`</code>  | 50 pytest contro live API + MongoDB |
| <code>`frontend-build`</code> | <code>`yarn build`</code>           |
| <code>`security-scan`</code>  | bandit + safety                     |
| <code>`docker-build`</code>   | build immagini backend e frontend   |

Secrets richiesti

| Secret                        | Obbligatorio       | Descrizione             |
|-------------------------------|--------------------|-------------------------|
| <code>`OPENAI_API_KEY`</code> | No (skip test LLM) | Per test LLM end-to-end |

## 27. Monitoring, logging, backup

### Logging

- Backend: log strutturato Python su stdout (catturato da Docker)
- Frontend: errori inviati a Sentry (opzionale)

### Metriche consigliate (Prometheus + Grafana)

- Latenza endpoint
- Tasso errori 5xx
- Numero token LLM consumati
- Numero conflitti aperti

### Backup MongoDB

- Atlas: snapshot continuo nativo
- Self-hosted: mongodump cron giornaliero su S3
- Retention: 30 giorni minimo

### Health check

- GET /api/health -> 200 OK (da implementare se non già presente)
- Docker healthcheck configurato nel docker-compose.yml

## 28. Troubleshooting comune

| Sintomo                | Probabile causa                 | Soluzione                             |
|------------------------|---------------------------------|---------------------------------------|
| Login non funziona     | JWT_SECRET_KEY mancante         | Setta variabile e riavvia             |
| ARIA non risponde      | OPENAI_API_KEY non valida       | Controlla key, verifica balance       |
| Conflitti non rilevati | Policy senza `regulation`       | Compila campo regulation              |
| PDF non generato       | Carattere mancante in ReportLab | Verifica fonts installati             |
| 504 backend            | MongoDB lento                   | Aumenta `pool_size`, controlla indici |
| CORS error             | `ALLOWED_ORIGINS` mancante      | Aggiungi URL frontend                 |
| Frontend bianco        | `REACT_APP_BACKEND_URL` errata  | Controlla `.env`                      |



## Logs utili

```
docker-compose logs -f backend
docker-compose logs -f frontend
docker-compose logs -f mongo
sudo supervisorctl status # se installato via supervisor
tail -n 100 /var/log/supervisor/backend.*.log
```

# 29. Appendice — Credenziali e link utili

## Credenziali demo

| Ruolo | Username | Password           |
|-------|----------|--------------------|
| Admin | `admin`  | `AdminGovern2026!` |

*Cambiare immediatamente in produzione.*

## Link

- **Repository GitHub:** <https://github.com/AngeloAng94/GOVERN.AI>
- **Swagger:** <http://localhost:8001/docs>
- **ReDoc:** <http://localhost:8001/redoc>

## Contatti supporto

### Angelo Anglani — Founder

- [angelo.anglani94@gmail.com](mailto:angelo.anglani94@gmail.com)
- +39 342 754 8655
- [linkedin.com/in/angelo-anglani](https://linkedin.com/in/angelo-anglani)

\*GOVERN.AI — Sovereign Control Plane for Enterprise AI.\*

\*Un prodotto di ANTHERA Systems.\*

\*Manuale aggiornato al 14 Maggio 2026 — MVP v3.0\*